

HRMS v2.0 Migration - TO DO List

Living document - updated as tasks complete. Source of truth for the migration's remaining work.

Milestone status

Completed tasks	29 / 30
Current branch	main @ dbd669c
Next task	Phase 5: final cutover to public (traffic switch is the last operator action)
Follow-up progress	8 / 8 done
Phase 0-1 progress	3 / 3 done
Phase 2 progress	2 / 2 done
Phase 3a progress	3 / 3 done
Phase 3b progress	9 / 9 done
Phase 4 progress	3 / 3 done
Phase 5 progress	0 / 1 done
Phase 6 progress	1 / 1 done

TO DO / status by phase

Phase 0-1 (3/3 done)

DONE	Freeze the v1.0 DuckDB schema; inventory tables for ETL Schema freeze note in docs/MIGRATION.md (08f7e40)
DONE	Build v2.0 target schema (db/postgres_schema.sql + Alembic baseline) 50-table public schema, CC-01..CC-16 documented (08f7e40)
DONE	One-time DuckDB -> PostgreSQL ETL with reconciliation hrms DB seeded; counts reconciled (08f7e40)

Phase 2 (2/2 done)

DONE	DuckDB->psycopg adapter (db_backend.py): translate/strftime/autocommit App runs on PostgreSQL legacy schema (b9164f2)
DONE	Unit + browser suites green on PostgreSQL (legacy schema preserved) 29/29 unit, 15/15 Playwright (b9164f2)

Phase 3a (3/3 done)

DONE	Argon2id password hashing; legacy bcrypt re-hashed on login security.py (98563ee)
DONE	Global CSRF enforcement (fetch wrapper + csrf_token field + token API) 98563ee
DONE	Server-side Redis sessions (REDIS_URL opt-in) + login rate limiting 98563ee

Phase 3b (9/9 done)

DONE	CC-01 identity rule enforced: scripts/check_cc_rules.py + PG-gated test 46 identity + 4 natural keys, sequences ahead of data (acb5219)
DONE	Public-flip readiness probe (scripts/probe_public_flip.py) GET + write-flow matrix against a throwaway public DB (acb5219)
DONE	Boolean adapter compat: predicates, INSERT params, naive datetime round-trip Inert on legacy (zero boolean cols); PG-gated tests (21480fe)

DONE	Write-flow probe + salary_structures seed data fix (CC-05) 11/11 core write flows green on public (21480fe)
DONE	CC-09 transactional outbox (outbox.py + scheduler + admin endpoints) Atomic business-write + event; backoff -> dead-letter (7e52f88)
DONE	CC-07 idempotency: @idempotent decorator + idempotency_keys wired for keyed POST retries Replay-without-duplicate, 409 on body reuse, claim released on failure; 6 unit tests green on every stack; probe replays on pure v2.0 JSONB
DONE	Service-layer rewrite inc 1: expanded audit_log (actor/entity/entity_id/before/after/request_id, CC-13) + notifications.category (FR-NOT-03) 8ff66bc; +6 unit tests; DuckDB 46 green
DONE	Service-layer rewrite inc 2: shift_assignments replaces users.shift_start/shift_end (FR-ATT-17); init_db no longer mutates v2.0 public.users get_shift/set_shift helpers reroute ~10 touch points; user CRUD + seed via set_shift; public probe 42/42 write flows
DONE	Extend probe write section: forgot-password, payroll bank-file/TDS, ticket/ATS + verify against a clean public schema Clean hrms_probe re-run: 94/94 GET + 42/42 write flows, including attendance, payroll, and lifecycle paths; all seed-time writes green

Phase 4 (3/3 done)

DONE	Attendance finalisation job (FR-JOB-01) 7 acceptance tests + nightly scheduler + regularization recompute; clean public probe 94/94 GET + 42/42 write
DONE	Maker-checker payroll (FR-PAY-06) Strict state machine + approval trail + Finance/Admin UI; clean public probe 94/94 GET + 42/42 write
DONE	Corrected ATS / onboarding / offboarding flows FR-ATS/FR-ONB/FR-OFF acceptance suite + 94/42 public probe

Phase 5 (0/1 done)

IN PROGRESS	Final cutover: flip APP_DB_SCHEMA to public, retire legacy Disposable rehearsal passed ETL/preflight/94-42 probe/authenticated smoke/CC-01 sequence check; maintenance-window traffic switch pending
----------------	--

Phase 6 (1/1 done)

DONE	Decommission DuckDB runtime PostgreSQL-only: APP_DB/DB_FILE, driver, legacy compose profile, ETL script and fallback lock removed; the per-session 50MB test-file leak is gone with the backend; 217 passed / 1 skipped in 67s
------	--

Follow-up (8/8 done)

DONE	FR-USR archive/restore and session revocation Hard delete replaced with retained archive/restore; admin UI and cross-backend tests updated
DONE	FR-USR directory contract (bounded pagination, sorting, validation) per_page capped at 200, allow-listed sorting, EMP/email/role/departement validation, case-insensitive uniqueness, partial PUT with role-change audit, CSV import under the same contract
DONE	FR-USR-09 permission policy (policy.py matrix + permissions API/UI) 27-module role matrix, deny-beats-allow overrides, full-replace PUT with audit diff, anti-lockout guard, admin permissions modal
DONE	FR-USR-15 policy enforcement wiring (decorators + navbar) Role gates narrowed by policy.can(); navbar derived from the same gate/module tags; department grant modelled; nav/API drift tests
DONE	FR-USR-15 inline scope checks + audited pii_reveal No handler branches on the session role copy; can_view_all is the CC-11 scope half; PII reveal route audited per cross-employee read
DONE	FR-LEA-06/08 policy-derived leave balances Entitlement derived from the effective leave_policy_assignments; reserved ledger enforced; audited policy API + admin modal

DONE	FR-USR-04 background bulk import jobs 202 + queued import_jobs, single-claim dispatcher, progress/history/cancel, upload deleted, audited completion
DONE	FR-USR two-person anonymisation proposed -> confirmed by a different approver -> applied; archived-only; dry run; value-scrubbed audit history; required salt; trade-offs recorded in docs/ANONYMISATION.md

Test & readiness gates

Gate	Stack	Current result
Unit suite (tests/test_app.py)	PostgreSQL	217 passed, 1 skipped (public-only shift test)
Unit suite (tests/test_app.py)	PostgreSQL + Redis	217 passed, 1 skipped
Browser suite (tests/test_playwright.py)	PostgreSQL	21 passed (threaded server, live scheduler)
CC-01 rule checker (scripts/check_cc_rules.py)	hrms_probe (public)	OK - every surrogate key is identity, sequences ahead of data
CI PostgreSQL job	postgres:17 + redis services	Unit suite on legacy (with and without Redis), browser suite, and the preflight/CC-01/probe gates on a clean v2.0 target
Public-flip probe (scripts/probe_public_flip.py)	hrms_probe (public)	97/97 GET + 44/44 write flows; lifecycle + permission + import paths included
Cutover preflight (scripts/cutover_preflight.py)	hrms (public)	Ready: head 0005, identity/sequence rules, required tables, and delta report generated
Disposable Phase 5 rehearsal	hrms_cutover_rehearsal	ETL Phase-1/2 + CC-05 cleanup + preflight + 94/42 probe + authenticated smoke + CC-01 sequence check passed

Update log (newest first)

2026-10-02	FR-AUTH-01: the rate limits made the SRS's own NFRs unsatisfiable. The load test the SRS asks for was never written, so the section 10 numbers were asserted and never measured - and writing the harness immediately found a launch blocker no amount of reading would have. Two per-IP-only limiters, both wrong by an order of magnitude: DEFAULT_RATE_LIMIT was 200 per minute keyed by get_remote_address against a sustained target of 150 req/s = 9,000 req/min, 45x short. The shared-NAT consequence is the blocker: measured with 15 distinct employees behind ONE egress address, 25 reads each, 200 of 375 served and 175 x 429 - the 200 is exactly the per-IP bucket, so the first users' ordinary browsing consumed the whole company's budget. With the SRS's own 500 concurrent sessions behind one corporate NAT that is 0.4 requests per minute per user, and behind a reverse proxy every user looked like one address. After the fix, 375/375 served and 0 locked out - and the same check run against the stashed pre-fix code reproduced the failure, because a check that cannot fail proves nothing. LOGIN_RATE_LIMIT was 20/min against a burst target of 200/min (1,000 logins in a 5-minute shift-start window), refusing 90% of a legitimate shift start before anyone mistyped a password. The fix is the split the SRS already names: the global key is the EMPLOYEE identity once authenticated and the remote address only while anonymous - anonymous traffic is the surface actually worth limiting, being the only one an attacker can hammer without credentials. Keyed on identity rather than session, so ten browser tabs do not buy ten budgets and session multiplication buys nothing. Raising the login limit to 200/min is only safe because FR-AUTH-03 exists: the 20/min address limit was standing in for per-account protection, and lockout.py now locks an employee after 10 consecutive failures in 15 minutes. A test of mine asserted the wrong thing and the correction is recorded rather than the assertion loosened: the first ratchet compared DEFAULT_RATE_LIMIT against 9,000 req/min and failed, but the COMPARISON was the error - 150 req/s across the API is an aggregate and the limit is now per employee. The old 200/min was broken precisely because it was an aggregate number applied as a per-user one. The test now checks the per-employee floor (the admin dashboard polls every 5 s, 12/min by itself, plus panels) and that 500 sessions clear the aggregate target. A harness flaw would have produced a fake finding too: loadcheck first reported a 17% error rate because its endpoint list included the admin-only dashboard-stats and it counted the correct 403 as a server fault. Measured after the fix at 80 req/s: p95 181ms, p99 226ms, 0.000% errors, 0 lockouts, against SRS targets of p95 under 300ms, p99 under 800ms and errors under 0.1%; before the fix the same run produced 141 lockouts and 13% errors. ops/load/load.js is the k6 scenario the SRS names, and it refuses to run against an MFA-enrolled account rather than measuring a wall of 401s, because FR-AUTH-11 makes a second factor compulsory for Admin, HR and Finance. Matrix moves FR-AUTH-01 to IMPLEMENTED: 60 IMPLEMENTED / 36 PARTIAL / 7 NOT_STARTED / 1 RETIRED. Unit 269 passed / 2 skipped, browser 22/22, v2.0 gates 111/111 GET + 55/55 write, probe run twice for idempotency. A sixth cleanup-helper failure, and the fix that ends the class: removing the temporary load-test employees raised an FK violation from leave_balance, and this file has listed the referencing tables wrongly three times, so the cleanup now discovers all 35 of them from information_schema instead of listing them.
------------	---

2026-10-02	Backup + restore drill (SRS 10: daily full backup, WAL archiving, 30-day retention, quarterly restore drill - none of it existed). scripts/backup.py provides backup, list, restore and verify; verify is the one that matters because it restores into a scratch database and then runs the application's OWN gates against it (check_cc_rules, cutover_preflight), since restoring is the easy half and a backup that restores into a database the app would refuse to run is not a backup. It also checks a row count, because every gate passes on an EMPTY database - that is the specific way this class of check lies - so users=0 fails and so does a dump with no users table at all, which is what a backup of the wrong database looks like. Both directions were run: a real backup verified green (exit 0) and a deliberately empty dump verified red (exit 1) with a diagnosis rather than a crash, because a drill that cannot fail is not a drill. WAL archiving is deliberately NOT implemented and says so: PITR needs a WAL destination and a retention policy belonging to whoever owns the storage, and a script that pretended to do it would be worse than one that declines. The container fallback is real rather than a comment - the dump is STREAMED through docker exec because a host path is not visible inside the container, and the DSN endpoint is rewritten to the container's internal port. Three connection bugs came out of writing this; the instructive one is that rebuilding netloc from the host alone THREW THE CREDENTIALS AWAY, surfacing as 'role root does not exist', a failure that looks like a database problem and is not one. Two DSNs are used on purpose: psql inside the container needs the internal endpoint, the Python gates run on the host and need the published port. Cron runs at 03:17 rather than 03:00 so a full dump does not compete with the 02:05 attendance finalisation, and the quarterly drill exits non-zero so an unwatched run still leaves a record of having failed. backups/ is gitignored: a dump is a full copy of every employee record.
2026-10-02	Go-live review: three of the five blockers turned out to be mine to fix rather than operator tasks. (1) send_email returned TRUE when SMTP_HOST was unset, logging 'would send'. Every delivery path goes through the outbox, so with the default configuration the event was marked delivered, the outbox monitor showed nothing wrong, the queue drained cleanly - and no human ever received a password reset link, while the employee had already been told the link had been sent. Found by auditing work done WITH the behaviour: FR-AUTH-08 was rebuilt this session so the response carries nothing, which is only an improvement if the link is actually delivered, and my own test asserted 'the queue drains', which was the bug. Reporting success for a send that did not happen is worse than having no email feature at all. Now a failure, so the event retries and dead-letters. The 202 stays uniform and cannot mention SMTP without becoming an enumeration oracle. (2) SRS 11.3 names Flask-Talisman, CSP with no inline scripts, nosniff, X-Frame-Options DENY, Referrer-Policy and HSTS, and the application shipped NONE of them - grep found only SESSION_COOKIE_SECURE. CSP is a module constant so the test asserts the configuration the app boots with rather than a hand-copied duplicate that would only check itself; script-src carries no unsafe-inline per the SRS's own parenthetical and the single relaxation is style-src, narrow and commented. frame-ancestors 'none' and X-Frame-Options DENY are both sent because CSP is not honoured everywhere the SRS targets. Disabled outside production deliberately: a CSP that fires on every local page load is one people learn to ignore. The test boots a real production app in a subprocess, because re-initialising Talisman onto the suite's app registered two after_request handlers that interfered and the tempting fix was to loosen the assertion until it passed. (3) FR-JOB-05: 'start in the unicorn master' is right for one instance and silently wrong for several, since every pod has its own master, so an N-pod deployment ran every cron job N times - unnoticed because duplication was mostly absorbed by idempotency built for other reasons. scheduler_leader.py is a Redis lease with token-fenced renewal via Lua compare-then-extend (a GET/PUT pair would let a stale leader overwrite the new leader's token), and a lost lease shuts the scheduler down. A configured but unreachable Redis refuses to start the scheduler: _redis() returns None for both 'not configured' and 'unreachable', so without an explicit check a broken lease store falls through to the legacy heuristic and every pod starts its own scheduler - the exact bug, reached by the most innocent-looking route. The SRS chaos test is literal: three competing OS processes race and exactly one wins, with three distinct identities. Also: both password-reset routes had a hardcoded 5/min limit neither suite lifted - the second LOGIN_RATE_LIMIT gap - now env-overridable; and a new /api/health reporting degraded rather than unhealthy when SMTP is unconfigured, when outbox events have dead-lettered, and which instance holds the scheduler lease, because a 200 only proves the process is up. Matrix now 59 IMPLEMENTED / 37 PARTIAL / 7 NOT_STARTED / 1 RETIRED. Unit 265 passed / 2 skipped (the leader chaos test skips without REDIS_URL and passes with it), browser 22/22, Redis 10/10, v2.0 gates 111/111 GET + 55/55 write.

2026-10-02	Group 3 of the audit: every mutating handler now writes an audit row except one deliberate exemption, so FR-AUD-01's 'every mutating action' holds in substance and the row stays PARTIAL only because the SRS also asks for the row to be written via the transactional outbox and audit_log() writes straight to the table. Nine handlers fixed: payroll run creation, asset issue, salary structure, import job cancel/run, the manual offboarding access-revocation pass, the break-approval request, and the regularization request - plus return_asset, which had the always-200 lie for the THIRD time: it updated unconditionally and answered 200 {'message': 'Asset returned'} whether or not it returned anything, including for an id that does not exist. That one has a custody consequence - an admin told a laptop came back when it did not is how one goes missing quietly - so it is now 404 for unknown and 409 naming the date it was already returned. The exemption is mark_notifications_read: a read receipt on the caller's own notifications, where a row per click is noise that makes the real entries harder to find. It stays on the ratchet list rather than being deleted, because a name there is a claim someone has to re-justify whereas an absence is indistinguishable from having been forgotten. Two design notes worth keeping: salary AMOUNTS are deliberately not copied into the audit row, because the log is retained for years and must not become a second weaker copy of the payroll tables - the audit records that a structure changed and for which period, and salary_structures remains the record of what it is. And the ratchet now holds one name, having started at twenty. Two of my own bugs in this slice, both caught immediately: the assets insert I wrote had nine parameters for ten placeholders because return_date is still a placeholder and only status is a literal - which is exactly the class of defect the edit existed to remove - and a break test leaked a notification row into an unrelated test, the fourth fixture leak in that file. Unit 258 passed / 1 skipped, browser 22/22, Redis 10/10, v2.0 gates 109/109 GET + 55/55 write.
2026-10-02	Group 2 of the audit: two more bare INSERT INTO VALUES (...) in documents_api and dependents_api, and three exemption calls. Neither bare insert is a live failure - both tables have the same column count and order on legacy and on v2.0 public today - which is exactly why it was worth fixing: the bug is invisible until someone adds a column, which is what happened with POST /api/goals (ten placeholders, nine columns, 500 on every backend) and add_holiday (five placeholders, v2.0's six, every value mis-targeted). Both times the boot seed kept working because the seed names its columns, and both of these had a seed insert two functions above writing the column list out. The guard is a test rather than the fix: it parses db/postgres_schema.sql for each table's declared columns and asserts the route's list still matches, so adding a column without updating the route fails there instead of at the public flip. Three 'should this audit?' calls did not go as predicted: mark_notifications_read is deliberately EXEMPT (a read receipt on the caller's own notifications is a row per click, and noise that makes real entries harder to find is the opposite of the point) and the exemption is recorded in the ratchet with its reason; admin_outbox_dispatch is NOT exempt because a dispatch sends email to employees and 'who forced the queue out and what did it deliver' is the question an operator pressing it at the wrong moment needs answered; send_notification_email is NOT exempt and is audited on BOTH paths, because an admin route that mails any address with any body is a data-exfiltration route by construction and recording only the successes would hide the attempts that matter. add_holiday audited nothing while its edit already did, so a holiday could be added to the company calendar with no record and then edited with one. Ratchet 15 -> 10 handlers (14 gaps + 1 documented exemption). One browser run failed 2 tests and the cause was self-inflicted: the probe and the Redis suite were run concurrently with the browser suite against the same PostgreSQL instance, and two timing-sensitive tests failed; re-run alone it is 22/22. Investigating it surfaced two real weaknesses, both fixed - _login's MFA panel window was 5s, which on a loaded machine reads as 'no MFA' and then times out waiting for a dashboard that never arrives, and test_admin_edits_user_permissions used three fixed sleeps before asserting the permission grid had rendered. Fourth and fifth instances of sleep-vs-signal in that file. Unit 256 passed / 1 skipped, browser 22/22, Redis 10/10, v2.0 gates 109/109 GET + 55/55 write.

2026-10-02	Break-lifecycle audit (FR-ATT-03/06/16): four requirements whose notes asserted behaviour the handlers did not have, in six handlers. FR-ATT-06's gate was @admin_required while the SRS says the employee's MANAGER (or HR/Admin) may approve - so a Team Leader could not approve their own report's break. That is the THIRD instance of that bug here, after FR-EXP-03 (Approved -> Paid unreachable for Finance) and FR-PERF-01 (goal rating unreachable for the reporting manager), and all three were recorded as implemented while the decorator made them impossible. Fixed by reusing the reporting_line_required gate from the goals work rather than writing a fourth. The same row claimed a conditional write that was unconditional (approve filtered on Pending in the SELECT but the UPDATE had no status guard, so two approvers both won), an audit that did not happen, and a notification that was never sent. reject_break also had the always-200 lie already fixed in regularization - it answered {'message': 'Break rejected'} whether or not it rejected anything; two routes in two unrelated slices carrying the same bug is the argument for sweeping siblings rather than fixing one at a time. FR-ATT-16 claimed 'an audited reason' for a route with neither an audit row nor a reason parameter; the reason is not cosmetic, since disposing ends ANOTHER employee's break and so shortens their attendance and their pay, and a blank reason is refused rather than defaulted, lands in the audit row and is sent to the employee. FR-ATT-03 claimed 'audited' and end_break audited nothing; start_break did not either despite silently auto-ending a previous break. One deliberate earlier decision had to be reversed: notifications.py mapped no rule for BREAK_* events on the reasoning that a rule to FALLBACK is a no-op that reads like data - true only while nothing emitted one. FR-ATT-16's notification now does, the emitted-types test forced the decision exactly as its author predicted, and break events are named Attendance (a fourth documented extra). Not a free win: naming it makes break events preferenceable, so an employee can now mute them where the catch-all delivered them unconditionally; the module's own principle settles it. PUNCH still emits nothing and still falls to the catch-all, and the test asserting the old behaviour was rewritten with the reasoning rather than quietly flipped. The audit ratchet caught five of its own names going stale the moment they started auditing - 20 handlers down to 15. Unit 253 passed / 1 skipped.
2026-10-02	Audit pass over the IMPLEMENTED rows, after three requirements in a row turned out to be recorded as done and not be. Four findings. FR-AUTH-07's row claimed 'unauthenticated gets 302 for a page and 401 for JSON', but _wants_json checked is_json and the /api/ path and NOT the Accept header the SRS names, so GET /dashboard with Accept: application/json answered 302 to the login page - HTML for a caller that asked for JSON, which then follows the redirect and cannot parse what it got. Identical to the multipart failure fixed in the FR-HOL-01 slice, one trigger earlier; now honoured, with a combined Accept still redirecting so browsers are unaffected. FR-REG-03's approval route had its success return OUTSIDE the if that did the work, so every outcome was a 200: a non-existent request, an already-decided one, and - the one that mattered - rejecting an already-approved request, which answered {'message': 'Rejected'} while the row still said Approved, so a client checking status_code believed a decision it had not made. It also audited nothing, so an attendance correction feeding payroll left no trail. Now 404 for unknown, 409 naming the state found, conditional write, before/after audit. FR-AUD-01 was downgraded IMPLEMENTED -> PARTIAL: 'every mutating action' was false. Document deletion wrote no audit row while document DOWNLOAD did, which is backwards, since deleting removes the row and the file; deleting a dependent erased policy-classified PII with no trail. Both fixed. The other 20 unaudited mutating handlers are named in the row and held by a ratchet test that fails if a new mutating route skips the audit log and fails if a stale entry is left behind. FR-AUTH-12 and FR-USR-06 notes corrected: the CSRF token is a per-session synchroniser, not the double-submit cookie the SRS describes, and enforcement is app-wide rather than /api/-scoped - both stricter, but the note described something the code does not do. FR-USR-06 names bank details among the identifiers to scrub and no such column exists, so that clause is vacuous; a test now fails if a personal column is added without being taught to the eraser. Matrix is now 58 IMPLEMENTED / 37 PARTIAL / 8 NOT_STARTED / 1 RETIRED.

2026-10-02	FR-AUTH-08/09 password reset: FR-AUTH-08 was recorded IMPLEMENTED and was the worst control failure in the application. /api/forgot-password answered 404 {'error': 'No matching user found'} for an unknown account and 200 *carrying the working token* for a real one - the control inverted rather than weakened, since a caller could confirm any employee ID and, if the email matched, obtain a credential without ever touching the account. Four request shapes now answer a byte-identical 202 with the SRS's own sentence and no token, and the token moved to the outbox, which is where the SRS puts it and what makes an empty response possible; the token row and its delivery event commit together (CC-09). FR-AUTH-09's row was wrong twice: it said the token was stored unhashed, which was half true and arguably worse, because hashing existed on the write path while /api/reset-password looked tokens up as token IN (raw, digest) to accommodate two plaintext tokens the boot seed wrote - so a database read still yielded two usable credentials on every fresh database; and it said the expiry should be 24 h, which is wrong - that token belongs to FR-USR-02's welcome email, while FR-AUTH-09 specifies 1 h, which the code already used. Also added the half that mattered: ALL other live tokens for the account are invalidated on a successful reset, because otherwise an attacker who requested their own reset while a legitimate one was live kept a working credential after the legitimate user reset theirs, and the single-use write is now conditional on used = 0 so two concurrent replays cannot both win. The emailed URL did not exist either - the SRS points at /reset-password?token=... and that was a 404, so the journey was reachable only by calling the API and reading the token out of the response; the page now exists and never interpolates the token into the HTML. A browser test caught a real UI bug in it: the success message was inside the form, and success hides the form, so the confirmation was hidden with it. Matrix is now 59 IMPLEMENTED / 36 PARTIAL / 8 NOT_STARTED / 1 RETIRED, and the generator's closing section now warns that the rows worth auditing next are the ones asserting something is finished - FR-AUTH-02 and FR-AUTH-08 were both recorded IMPLEMENTED and both were not, and neither was found by reading the code for its own requirement but for a neighbouring one.
2026-10-01	FR-AUTH-03 account lockout, and the FR-AUTH-02 hole it exposed: the SRS is four numbers - 10 consecutive failures within 15 minutes lock the account for 15 minutes and notify the user by email - and lockout.py implements exactly those, asserted by a test so a threshold nobody agreed to cannot hide in a constant. A successful sign-in breaks the streak and the window slides, because without both, four typos spread over a week lock an employee out and a lifetime counter trains people to write passwords on sticky notes. An admin can clear a lockout without touching users.status: a lockout is a temporary consequence of wrong passwords while Blocked is a sanctioned account state, and folding them together writes an HR record against a fifteen-minute nuisance. Deliberate deviation, recorded in the matrix: the SRS flow diagram puts the counter in Redis and it is stored on users instead, because this app treats Redis as optional and a lockout that silently stops existing when Redis is unreachable has failed open rather than degraded - the same rule that put the password-policy corpus offline. Alembic 0009 adds three additive columns, no backfill, and no index, since nothing queries by locked_until. The consequential find was reading the login handler to wire it up: FR-AUTH-02 was recorded as IMPLEMENTED while the route answered two different 401 messages and two 403s ('Account is blocked', 'Login is not allowed') - the exact state leak the requirement forbids, and adding a lockout would have added a third. All six refusal paths are now one 401 {'error': 'invalid_credentials'}, the password is verified before any state is considered so timing says nothing either, and a test asserts all six answers are byte-identical. The obvious feature - a 'locked, try again in 14 minutes' banner on the login page - was built and then removed: it is the enumeration channel the requirement forbids, which is why the SRS pairs the lock with a notification instead. Matrix is now 58 IMPLEMENTED / 37 PARTIAL / 8 NOT_STARTED / 1 RETIRED.

2026-10-01	FR-AUTH-11 multi-factor authentication: the largest single gap the traceability pass found - mfa_credentials was in the canonical schema with an encrypted-secret column and no code anywhere that read or wrote it, no enrolment, no challenge, no gate. mfa.py now owns TOTP (RFC 6238), Fernet encryption under a dedicated MFA_ENCRYPTION_KEY (a missing key is a 503 refusal, never plaintext storage, mirroring ANONYMISATION_SALT), the pending-login state machine and the attempt cap. Enrolment is two-phase: /api/mfa/enrol writes the row with enabled=0 and only a valid code at /api/mfa/confirm promotes it, so a stolen password cannot enrol an attacker's own authenticator against the account. The password step parks the identity in session['mfa_pending'] and deliberately does NOT set session['emp_id'], so a half-authenticated session is refused by every existing gate by construction rather than by each route remembering to check. Compulsory for Admin/Super Admin/HR/Finance, self-service opt-in for everyone else; a mandatory role cannot disable its own factor and re-enrolment while enabled is a 409. Five wrong codes abandon the parked login; one step of clock drift is tolerated; the pending state expires after ten minutes. Recovery is an audited Admin reset only - no recovery codes, which is the weaker answer the SRS allows, so the reset answers identically whether or not the target was enrolled (it cannot be used to find out who is protected) and writes a before/after audit row. Two real bugs found while validating: the login page built the finishing endpoint as '/api/mfa/' + step, pointing the enrolment submit back at /api/mfa/enrol - which mints a new secret - so the code the user had just read stopped matching and the page navigated on without verifying anything; and signing in as a second account in the same browser kept the first account's session, because the cookie survives and _mfa_subject prefers session['emp_id'], so the enrolment and challenge both acted on the wrong person. Fixing that also closed a pre-existing leak where a test blocked the seeded EMP002 and never restored it. Matrix is now 57 IMPLEMENTED / 37 PARTIAL / 9 NOT_STARTED / 1 RETIRED.
2026-09-30	FR-HOL-01/02 holiday calendar: the duplicate rule was a SELECT in the route, which is a message and not a rule - two concurrent adds both passed the check and both inserted. It is now a unique index, and the obvious constraint would have been wrong: a plain UNIQUE(name, holiday_date, location) accepts duplicate org-wide holidays because NULL is distinct from NULL in SQL, so the index is on COALESCE(location, "") and the application builds the identical triple. Added the missing update, year-to-year copy that skips rather than shifts a 29 February holiday, CSV import/export, an iCal feed that uses DTSTART;VALUE=DATE and folds every line to the 75-octet RFC 5545 limit, and a delete that is refused while opt-ins reference the holiday. The consequential find: the role gates decided 'is this an API call?' with request.is_json, which is False for a multipart upload, so every admin-gated upload route answered a non-admin with a 302 to dashboard HTML that a fetch client follows and cannot parse, with a 200 status. app._wants_json() now keys on the path as well. Matrix is now 56 IMPLEMENTED / 36 PARTIAL / 11 NOT_STARTED / 1 RETIRED.
2026-09-30	FR-HOL-03 optional-holiday opt-ins: a defect rather than a feature. holiday_optins existed in the canonical schema, init_db created it on the compatibility shape, and nothing ever wrote to it. An Optional holiday is an attendance holiday only for an employee with an Approved opt-in, no employee could ever obtain one, and the nightly FR-JOB-01 finalisation recorded the seeded Diwali as Weekly-off and would have said Absent on Christmas - an implemented High-priority requirement producing a wrong answer. Employee requests, HR approves or rejects from a queue, the owner may withdraw. The canonical schema also contradicted the requirement and itself: uq_optin was a plain UNIQUE (emp_id, holiday_id), a constraint on one request ever rather than one active request, which made opt-out irreversible, and it contradicted the partial uq_active_offer_candidate four lines above it. Alembic 0006 replaces it with the partial index. Also found a latent bare-VALUES insert in add_holiday (five placeholders against v2.0's six-column table) - the same shape that made POST /api/goals return 500 forever - and a latent VARCHAR(32) limit on alembic_version.version_num that fails at the version stamp rather than at the migration. Matrix is now 54 IMPLEMENTED / 38 PARTIAL / 11 NOT_STARTED / 1 RETIRED.
2026-09-30	FR-LEA-05 leave cancellation: the SRS asks for one sentence and there was no cancel route at all, so a Pending leave request reserved days against the employee's balance and nothing could ever give them back - a request that changed its mind silently reduced their remaining leave for the year. The decision and the reversal are leave_policy.cancel's, together, because the ledger effect differs by state: Pending releases the reservation, Approved takes the days back out of used_days, and releasing in that case would leave the balance understated with no way to detect it. The day count is the same expression the apply and approve paths use, so the reversal matches the reservation it undoes. Also fixed a latent test-isolation bug: the leave cleanup deleted the user before the rows referencing it, so the user survived a foreign-key error and the next test to reuse the id failed somewhere unrelated. Matrix is now 53 IMPLEMENTED / 39 PARTIAL / 11 NOT_STARTED / 1 RETIRED.

2026-09-30	FR-TKT-03/04 tickets: FR-TKT-03 asks for defence in depth on the visibility rule, and the list and detail view had it - but the two write paths did not. An unrelated employee's list was empty, the detail view returned 403, and POST /api/tickets/comment returned 201. update_ticket_status had neither a visibility check nor a state machine, so any authenticated user could move any ticket to any state and close anyone else's. tickets.py now holds one can_view rule for all four paths and the strict Open -> In Progress -> Resolved -> Closed chain, with Reopened as a real status: a Closed ticket reopens when its reporter comments within seven days, and an older closure stays closed. Assignment is audited, which FR-TKT-04 asks for and nothing did. The assignee can now see the ticket they were given, which the old rule prevented. FR-DOC-03 folded in: document downloads are audited. This slice also caught a bug in my own patch - jsonify(body, exc.status) returns 200 with a 409-shaped body, so every refused transition read as a success. Matrix is now 52 IMPLEMENTED / 40 PARTIAL / 11 NOT_STARTED / 1 RETIRED.
2026-09-30	FR-PERF-02 review integrity: the SRS has two sentences for this requirement and neither was enforced - submit requires the assigned reviewer (Appendix A-18, recorded as a v1.0 gap) and 360 feedback reviewer cannot be the subject. submit_review had no reviewer check at all, a self-review could be opened because both ids came from the body unexamined, a signed review could be reopened and rewritten because the write was unconditional, and anyone could rate themselves five stars. reviews.py owns the rules, and check_submit deliberately gives HR and Admin no bypass: the rule exists to stop a review being signed by somebody who did not write it. A self-review is refused at creation, the rating is bounded, Submitted is terminal with a conditional write, and the before/after is audited. The probe is also idempotent across runs now - its reset-password flow used to change EMP002's password permanently. Matrix is now 51 IMPLEMENTED / 41 PARTIAL / 11 NOT_STARTED / 1 RETIRED.
2026-09-29	FR-PERF-01 goals: POST /api/goals had never worked - a bare INSERT INTO goals VALUES with ten placeholders against a nine-column table, so every goal creation returned 500 on every backend. The seed used an explicit column list, which is why the seed worked and the create path did not, and no test or probe flow created a goal. PUT /api/goals/ was @login_required with no ownership check, so any authenticated user could rewrite any goal by guessing a sequential id, and could set status to skip rating. The rating enforced neither half of the SRS rule, and @admin_required excluded the reporting manager the requirement names - the same gate bug as the expense slice. goals.py now owns EDITABLE_FIELDS (no status, no rating), the edit ownership rule, and a rating that requires the reporting manager or HR/Admin and refuses the owner, with a conditional write on Active. A new reporting-line gate admits managers. Matrix is now 50 IMPLEMENTED / 42 PARTIAL / 11 NOT_STARTED / 1 RETIRED.
2026-09-29	FR-AUTH-10 password policy: a 10-character minimum (Appendix A-01 calls 6 a defect) plus a breach-corpus check, enforced wherever a password is set, with no complexity rules and no expiry by design per NIST SP 800-63B - a test parses the module's AST to keep them out. The corpus is offline by default (a check that fails when the network is down does not exist) with the HIBP k-anonymity range query behind HIBP_URL. Leet variants and known-password-plus-suffix are caught, and the rejection message is generic so it is not an oracle for confirming a guess. The shared default of pass123 is gone: a user created without a password now gets a generated compliant one returned once. Matrix is now 49 IMPLEMENTED / 43 PARTIAL / 11 NOT_STARTED / 1 RETIRED.
2026-09-29	FR-EXP-03 expense claim state machine: following the traceability matrix into expenses_api found three defects - an admin could approve a claim they had filed themselves, a claim could jump Pending to Paid with no approval, and a paid claim could be moved back to Pending - plus the CC-10 impersonation hole where emp_id came from the request body. expenses.py owns a strict transition table, blocks self-approval, gives Paid to Finance/Admin only (Appendix A-11), requires a rejection reason, and writes every transition as a conditional UPDATE with a before/after audit. The gate was the other half: admin_required excluded both the claim owner's manager and Finance, making Approved to Paid unreachable by the role the SRS names, so a new expense_actor_required gate admits manager, HR, Finance and Admin, and Finance now holds the expenses module. The matrix also corrected itself: the previous claim that FR-DOC-02 validated the file extension rather than the content was wrong - the upload route does sniff the magic number and reject EICAR. Matrix is now 48 IMPLEMENTED / 43 PARTIAL / 12 NOT_STARTED / 1 RETIRED.
2026-09-29	SRS traceability matrix: traceability.py maps all 104 SRS requirements to the routes that implement them, and docs/TRACEABILITY.md is generated from it. Four tests keep it honest - the id set must match the SRS, every route named must exist in the live url_map, an IMPLEMENTED row with no route must explain itself, and a PARTIAL row must name its gap. Verdicts: 47 IMPLEMENTED, 44 PARTIAL, 12 NOT_STARTED, 1 RETIRED. The largest gap found is FR-AUTH-11 MFA: mfa_credentials exists in the canonical schema with an encrypted secret and no code reads or writes it. Same shape for approval_delegations, notification_preferences and holiday_optins. Two security PARTIALs verified by reading the handlers: FR-DOC-02 validates the file extension rather than the content (no malware scan, a renamed .exe passes), and FR-EXP-03 has no self-approval block so an employee can approve their own claim.

2026-09-29	Server-side session coverage: CI re-ran the whole unit suite with REDIS_URL set, but no test in the suite referred to the session store, so the step passed identically whether the backend was Redis or the app had silently fallen back to signed cookies - which is what the first run of the new tests found. tests/test_redis_sessions.py is now its own pytest process (the backend is chosen when app is imported) and asserts the opaque cookie, the Redis payload and TTL, session persistence, logout deleting the key, block and archive revoking the session while an unrelated one survives, re-blocking after an unblock, CSRF still enforced, and both fallback paths. The duplicate 122-test CI step is replaced by these 10 tests.
2026-09-29	FR-LEA-08 monthly leave accrual: monthly_leave_grants was in the canonical target and unwritten, so an accrual rate was collapsed into a flat annual ceiling at assignment time. The rate-driven entitlement is now what the employee has earned so far (floor(rate x months elapsed) across the months the assignment was in force), posted one row per elapsed month by a monthly cron job, POST /api/accrual/run, or the Accrue now button in the leave-policy modal - all three idempotent. The entitlement is derived and the grant is the record, so a missed run cannot leave anybody with no leave; granted_by is NULL because it is a foreign key to users(emp_id) in v2.0. entitlement_days now takes the balance year, and a year the policy never reached keeps the published default. DuckDB 126 passed / 6 skipped; PostgreSQL 131 passed / 1 skipped; Playwright 21 passed; probe 97/97 GET + 45/45 write.
2026-09-28	FR-USR-15 PII completion: policy.PII_FIELDS is now a per-entity map, so a candidate's email and phone are withheld from /api/candidates and /api/offers unless the actor holds pii_reveal, each record carries pii_revealed, and a permitted read writes one PII_REVEAL audit row. A candidate's name is never withheld (a recruiter must know whose record they are editing) and dependents are classified but have no cross-employee read path. Also made the scheduler registration testable without starting a scheduler thread, which is what made the DuckDB unit suite intermittently fail. DuckDB 121 passed / 6 skipped; PostgreSQL 126 passed / 1 skipped; Playwright 21 passed; probe 97/97 GET + 44/44 write.
2026-09-28	FR-USR two-person anonymisation: propose then confirm-by-a-different-approver, applied by the system, archived accounts only, with a dry-run plan, a required ANONYMISATION_SALT, dependents erased and the statutory rows kept, and the subject's own audit history scrubbed by value substitution (including historical values, so a rename cannot leave the old name behind). Trade-offs taken on the operator's behalf - keeping emp_id as the seven-year join key and leaving free text - are recorded in docs/ANONYMISATION.md. Also added an on-demand import run route and made the DuckDB browser fixture scheduler-free. DuckDB 116 passed / 6 skipped; PostgreSQL 121 passed / 1 skipped; Playwright 21 passed; probe 97/97 GET + 44/44 write.
2026-09-28	FR-USR-04 background import jobs: POST /api/users/import now returns 202 with a queued job (5 MB / 5000-row caps, streaming validation, idempotent retry), a dispatcher claims one job per tick with a conditional status transition so several workers cannot collide, progress is published every 25 rows, the outcome is audited and the stored upload is deleted when the job settles. Added the import_jobs table via revision 0004_import_jobs plus the compat DDL, job status/history/cancel routes and a polling UI. Also fixed audit_log, which silently dropped every scheduler-thread write (the nightly ACCESS_REVOKED rows), and made the global rate limit overridable so a full suite no longer trips it mid-run. DuckDB 111 passed / 6 skipped; PostgreSQL 116 passed / 1 skipped; Playwright 20 passed; probe 96/96 GET + 44/44 write.
2026-09-28	FR-LEA-06/08 policy-derived leave balances: the entitlement now comes from the effective leave_policy_assignments (accrual rate x 12, capped by carry-forward) and falls back to the published defaults, so deriving changes nothing until a policy is assigned. The apply path always enforces (it used to skip employees with no row) and reserves the days while a request is pending, which is the first write to the reserved column and closes the double-spending hole. Added an audited policy API plus an admin modal. Also fixed the intermittent DuckDB browser-suite flake (DuckDB attaches a file once per process, so the dev server runs single-threaded there). DuckDB 107 passed / 6 skipped; PostgreSQL 112 passed / 1 skipped; Playwright 19 passed; probe 94/94 GET + 44/44 write.
2026-09-28	FR-USR-15 scope + PII: no handler branches on the session role copy any more (test-enforced), the company-wide list split became policy.can_view_all (CC-11 scope), the dashboard variant follows sees_admin_surface(), and pii_reveal is now enforced and audited: GET /api/users//pii is the only cross-employee personal-data read and every such reveal writes a PII_REVEAL audit row. DuckDB 102 passed / 6 skipped; PostgreSQL 107 passed / 1 skipped; Playwright 18 passed; probe 94/94 GET + 44/44 write.
2026-09-28	FR-USR-15 enforcement wiring: the four role gates now narrow with policy.can() (the role/department check stays the outer gate, so an empty override table is a no-op), every gated view is mapped to a module, and the navbar is derived from the same gate/module tags so a link exists only when the route would admit the user. The HR-department grant is modelled explicitly. Drift removed (Finance no longer sees 403ing links, Super Admin sees the admin links) and /admin/leaves is now reachable. DuckDB 97 passed / 6 skipped; PostgreSQL 102 passed / 1 skipped; Playwright 17 passed; probe 94/94 GET + 44/44 write.

2026-09-28	FR-USR-09 permission policy implemented: policy.py owns the 27-module role matrix with deny-beats-allow per-user overrides, GET/PUT /api/users//permissions does a full replace with an audit diff and an anti-lockout guard, and the admin user list gained a permissions modal. Empty overrides reproduce the role defaults exactly, so no existing authorization outcome changes; decorator/navbar enforcement is the next slice. DuckDB 90 passed / 6 skipped; PostgreSQL 95 passed / 1 skipped; Playwright 17 passed; public probe 94/94 GET + 44/44 write.
2026-09-28	FR-USR directory contract implemented: GET /api/users caps per_page at 200 and sorts through an allow-list (400 on invalid input), POST/PUT validate the employee ID, email, role, department and status with case-insensitive uniqueness, PUT became a true partial update with a before/after audit diff, and the CSV import now validates every row and reports skipped rows. Admin UI mirrors the contract; the public probe stays green.
2026-09-25	Phase 5 cutover rehearsal completed: frozen-source ETL accepted a missing post-v1.0 payroll_approvals table, reconciled Phase-1/Phase-2 data, applied CC-05 cleanup, stamped head, passed read-only preflight and 94/42 public probe, and kept identity sequences ahead after boot seeds and authenticated GET/write smoke. Traffic switch remains a maintenance-window operation.
2026-09-25	FR-ATS/FR-ONB/FR-OFF corrected lifecycle implemented: guarded ATS state machine, 100% offer splits, atomic accepted-offer conversion, signed pre-boarding tokens and real-file validation, five-step guarded onboarding, parallel offboarding with F&F; maker-checker, and IST LWD access revocation, plus lifecycle hardening (strict split precision, ETL preservation, session revocation, encrypted credential delivery, and document authorization). DuckDB 77 passed / 5 skipped; PostgreSQL 81 passed / 1 skipped; Playwright 16 passed; public probe 94/94 GET + 42/42 write.
2026-09-24	FR-PAY-06 maker-checker payroll implemented: Draft → Submitted → Approved → Finalized, Finance/Admin authorization, self-approval rejection, payroll_approvals trail, adjustment-run reference, Finance UI access, and public probe coverage. DuckDB 64 passed / 5 skipped; PostgreSQL 68 passed / 1 skipped; probe 86/86 GET + 30/30 write.
2026-09-24	FR-JOB-01 attendance finalisation implemented: nightly per-shift-date classification, employee weekly-off patterns, holiday/leave precedence, transactional attendance_days replacement, calendar output, and public identity-key probe coverage. DuckDB 64 passed / 5 skipped; PostgreSQL 68 passed / 1 skipped; probe 86/86 GET + 30/30 write.
2026-09-24	Service-layer rewrite inc 2/3 completed: shift_assignments, explicit v2.0 INSERTs, BOOLEAN UPDATE parameter coercion, and binary payroll bank-file export; the clean public-flip probe is fully green.
2026-09-23	CC-07 idempotent writes done: @idempotent decorator on 9 POST routes, idempotency_keys DDL + hourly purge, 6 unit tests green (DuckDB 40 / PG 43 / PG+Redis 43), probe replays on pure v2.0 JSONB -> 86/86 GET + 12/12 write. Next: service-layer rewrite.
2026-09-23	TODO list created. Next task slated: CC-07 idempotency.